UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 3 slot(s). Supported theory: 19 slots. Placeholders: 2.
Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 14 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 3 computed, 19 supported by lecture slides, 2 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - computed - matches lecture slides 5-9 (Caesar shift 3 examples)

Question:

Using Caesar Cipher technique, decrypt the following ciphertext with a shift of 7 (replace each letter with the one 7 positions to the left).
KLCPJLYLABYULKHUKDPWLKVUL

Answer: DEVICERETURNEDANDWIPEDONE

Working:

```
K (10) -7 mod 26 -> D
L (11) -7 mod 26 -> E
C ( 2) -7 mod 26 -> V
P (15) -7 mod 26 -> I
J ( 9) -7 mod 26 -> C
L (11) -7 mod 26 -> E
Y (24) -7 mod 26 -> R
L (11) -7 mod 26 -> E
A ( 0) -7 mod 26 -> T
B ( 1) -7 mod 26 -> U
Y (24) -7 mod 26 -> R
U (20) -7 mod 26 -> N
L (11) -7 mod 26 -> E
K (10) -7 mod 26 -> D
H ( 7) -7 mod 26 -> A
U (20) -7 mod 26 -> N
K (10) -7 mod 26 -> D
D ( 3) -7 mod 26 -> W
P (15) -7 mod 26 -> I
W (22) -7 mod 26 -> P
L (11) -7 mod 26 -> E
K (10) -7 mod 26 -> D
V (21) -7 mod 26 -> O
U (20) -7 mod 26 -> N
L (11) -7 mod 26 -> E
```

Suggested marks: 1 mark for identifying the cipher/shift direction; 1 mark for the complete plaintext.

Confidence: computed - matches lecture slides 5-9 (Caesar shift 3 examples).

A1b - 6 marks - PLACEHOLDER

Topic: classical ciphers; command: Describe

Status: placeholder - no supported question passed verification.

Reason: A1b point 6: marking point is a verbatim copy of its quote; phrase the point as an answer requirement, not as copied slide text

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List two transposition cipher techniques covered in the lecture and, for each, state how the cipher-text is produced from the plain-text.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Columnar transposition: the plain-text is placed into the rows of a matrix and the cipher-text is then read out column by column.	"put plain-text into rows of matrix then read cipher-text out of columns"	031 - Classical Cryptography, slide 20	031 - Classical Cryptography::s20::1	0.77	supported (stegate)
2	Rail fence: the plain-text is written in a zigzag pattern across rows, and the cipher-text is obtained by reading the letters off row by row.	"The plain-text is written in a zigzag pattern in rows and form the cipher-text by reading off the letters from the rows."	031 - Classical Cryptography, slide 25	031 - Classical Cryptography::s25::1	0.71	supported (stegate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 031 - Classical Cryptography, slide 20; 031 - Classical Cryptography, slide 25

A2b - 6 marks - computed - matches lecture slide 15 (standard tableau)

Question:

Decrypt the following ciphertext using the Vigenere cipher with the key CIPHER. Use the standard 26 x 26 Vigenere tableau, writing the key over the message and repeating it as necessary.
UMRBVVNWVPREQE

Answer: SECURELOGINNOW

The 26 x 26 Vigenere tableau is printed in the question paper.

Working:

```
Standard 26 x 26 tableau, A=0; key repeated over the ciphertext.
Ciphertext: UMRBVVNWVPREQE
Key:        CIPHERCIPHERCI
Letter-by-letter: C - K mod 26 = P
  U (20) - C ( 2) = 18 -> S
  M (12) - I ( 8) =  4 -> E
  R (17) - P (15) =  2 -> C
  B ( 1) - H ( 7) = 20 -> U
  V (21) - E ( 4) = 17 -> R
  V (21) - R (17) =  4 -> E
  N (13) - C ( 2) = 11 -> L
  W (22) - I ( 8) = 14 -> O
  V (21) - P (15) =  6 -> G
  P (15) - H ( 7) =  8 -> I
  R (17) - E ( 4) = 13 -> N
  E ( 4) - R (17) = 13 -> N
  Q (16) - C ( 2) = 14 -> O
  E ( 4) - I ( 8) = 22 -> W
Plaintext:  SECURELOGINNOW
```

Suggested marks: 1 mark for the key/table setup; 4 marks for the letter-by-letter working; 1 mark for the complete answer.

Confidence: computed - matches lecture slide 15 (standard tableau).

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) facts about the chain of trust in the Trusted Computing architecture, including how measurements are recorded and where the chain begins.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Each stage of the chain measures and validates the following stage.	"Each stage measures and validates the next one"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.60	supported (ste gate)
2	The measurements produced during the chain are stored in Platform Configuration Registers on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.56	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 8

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State SIX (6) facts about the two primary system components of the Next Generation Secure Computing Base (NGSCB), covering the Nexus and the Nexus Computing Agent (NCA).

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	NGSCB has two primary system components, namely the Nexus and the Nexus Computing Agent (NCA).	"Two primary system components"	073 - Trusted Computing, slide 13	073 - Trusted Computing::s13::1	0.14 LOW	partly supporte
2	The Nexus is a special kernel that forms the core of the trusted operating environment.	"Special kernel (core of the trusted operating)"	073 - Trusted Computing, slide 13	073 - Trusted Computing::s13::1	0.62	supported (ste gate)
3	The Nexus is a security kernel that is authenticated on boot.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.80	supported (ste gate)
4	The Nexus authenticates trusted programs.	"Authenticates trusted programs"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.75	supported (ste gate)
5	The Nexus provides the application interface to the TPM and does not trust the OS.	"Application interface to TPM"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.38 LOW	partly supporte
6	The Nexus Computing Agent is a trusted software component that runs in trusted mode and communicates with the Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.62	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 073 - Trusted Computing, slide 13; 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two ways in which the Chinese Wall model differs from traditional access control policies, referring to the type of concern it addresses and how access rights behave over time.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Chinese Wall policy is designed to	"Brewer and Nash's Chinese Wall Policy is designed to address a	024 - Formal Security Model,	024 - Formal Security	0.92	supported (ste gate)

	address a very specific concern, namely conflicts of interest involving a consultant or contractor.	very specific concern: conflicts of interest by a consultant or contractor."	slide 27	Model::s27::1		
2	Access rights in the Chinese Wall model change dynamically, since what a subject may access depends on the history of its past accesses.	"Notice that permissions change dynamically. The access rights that any subject enjoys depends on the history of past accesses"	024 - Formal Security Model, slide 24	024 - Formal Security Model::s24::1	0.61	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 24; 024 - Formal Security Model, slide 27

Status: computed placeholder - no question generated for this type.

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List the TWO (2) stages that make up the authentication process in a biometric system.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The identification stage, in which master characteristics are acquired, created and stored.	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.50	supported (ste gate)
2	The authentication stage, in which acquisition is repeated, a comparison is made and a decision is reached.	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.62	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

A bank plans to deploy biometric authentication at its branch counters. Explain the different categories of biometric technologies and the practical issues that must be considered when choosing a biometric mechanism for this deployment.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	State that biometric applications are divided into two sectors, namely physiological and behavioural.	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.57	supported (ste gate)
2	Give examples of physiological biometrics such as iris, fingerprints, hand, retinal and face recognition.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.60	supported (ste gate)
3	Give examples of behavioural biometrics such as voice, typing pattern and signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.57	supported (ste gate)
4	Explain that a biometric	"A biometric is a physiological or	072 - Biometrics	072 - Biometrics	1.00	supported (ste

	is a physiological or behavioural characteristic that can distinguish one person from another and can be used for identification or verification.	behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity."	and Authentication, slide 2	and Authentication::s02::1		gate)
5	Note that fingerprint biometrics suffer from disadvantages such as racial issues, dirt, grime and wounds, and finger placement.	"Racial issues Dirt , grime and wounds Placement of finger"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.54	supported (ste gate)
6	Note that fingerprint systems can be spoofed, so liveness detection is important.	"Can be spoofed - liveness important!"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) typical locations where network-based IDS sensors are placed in a network.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A sensor can be positioned just inside the firewall.	"Just inside the firewall"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.50	supported (ste gate)
2	A sensor can be positioned on the DMZ.	"On the DMZ"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.25 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 062 - Intrusion Detection System, slide 7

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain six (6) preventive network security mechanisms that an organization can deploy to protect its network, describing for each mechanism how it contributes to preventing or limiting security attacks.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A firewall filters traffic entering and leaving the network according to predefined security rules.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.30 LOW	supported
2	A proxy server improves data security and network performance by acting as a firewall and web filter, sharing connections and caching data.	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.79	supported (ste gate)
3	Network segmentation creates boundaries between segments	"Boundaries between network segments where computing assets within the segment have a	061 - Network Security, slide 3	061 - Network Security::s03::1	0.75	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	whose assets share a common function, risk or role.	common function, risk or role within an organization."				
4	A remote access VPN gives individual hosts or clients secure access to the organization network.	"Provides remote and secure access to an organization network to individual hosts or clients"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.89	supported (ste gate)
5	Zero Trust Network Access restricts each user to only the access and permissions needed for their role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.50	supported (ste gate)
6	IDS/IPS detect or prevent attacks such as brute force, denial-of-service and exploitation of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4	061 - Network Security::s04::1	0.85	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) characteristics of a Trojan horse as a type of malware.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Trojans typically disguise themselves as useful or benign software.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.00 LOW	supported
2	Trojans steal private information from the infected machine.	"begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.33 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six (6) techniques used by malware to propagate itself or to conceal its presence on an infected system, and explain the impact of each technique on the victim.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A boot sector virus saves the original master boot record in a safe location before overwriting it with an infected version.	"Save the original MBR in a safe location"	051 - Software Security, slide 8	051 - Software Security::s08::1	0.31 LOW	partly supporte
2	A COM executable virus appends its virus body to a program and replaces the program entry point with a jump to a virus body.	"Replace a program entry point with a jump to a virus body"	051 - Software Security, slide 9	051 - Software Security::s09::1	0.70	supported (ste gate)
3	An EXE executable virus overwrites a program header so that	"Over write a program header to switch the entry point to a virus"	051 - Software Security, slide 10	051 - Software Security::s10::1	0.67	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	the entry point switches to the virus.					
4	A rootkit masks malicious processes and software in the infected system to ensure privileged remote access.	"Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access."	051 - Software Security, slide 13	051 - Software Security::s13::1	1.00	supported (ste gate)
5	A rootkit is usually installed after a vulnerability has been found and detected, so the infected computer stays under the malware author's control.	"They are usually installed after a vulnerability has been found and detected so that the infected computer continues to be under the control of the malware author."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.87	supported (ste gate)
6	Spyware steals user logins and passwords, documents sites visited, logs keystrokes and redirects browsers, leading to identity theft and compromised bank information.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.61	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 8; 051 - Software Security, slide 9

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a buffer overflow arises in a program such as the web server function that copies input into a fixed-size local buffer, and state what an attacker can achieve by exploiting it.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The overflow occurs because the copying routine does not verify the length of the input string, so a longer string than the buffer can hold spills over.	"strcpy() do not check the string length"	051 - Software Security, slide 23	051 - Software Security::s23::1	0.17 LOW	supported
2	By controlling the overflowing content, the attacker can overwrite the saved return address with an arbitrary value and thereby hijack the execution flow of the program.	"By controlling buffer content, an attacker can overwrite the return address with an arbitrary value and hijack the execution flow."	051 - Software Security, slide 21	051 - Software Security::s21::1	0.69	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 21; 051 - Software Security, slide 23

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Windows is often described as offering rich built-in security, yet it remains a frequent target of attack. Explain six aspects of Windows security mechanisms, covering the overall nature of these mechanisms, the directory service for organising resources, how subjects and their credentials are handled, the registry's security role, the historical security milestones, and the risk that complexity itself creates.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Windows provides complex built-in mechanisms covering user accounts, object management and access control.	"Windows systems contain complex security mechanisms for user account and object management as well as access control."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.75	supported (ste gate)
2	Discretionary access control in Windows allows fine-grained control over diverse entities in the OS and in applications.	"DACS enable fine-grained access control of heterogeneous entities in Windows itself as well as applications."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.55	supported (ste gate)
3	Active Directory, introduced with Windows 2000, is an LDAP-like directory service used to organise system resources.	"Active directory introduced in Windows 2000 is an LDAP-like directory service for organization of system resources:"	041 - Windows Security, slide 6	041 - Windows Security::s06::1	0.91	supported (ste gate)
4	In Windows, subjects are processes and threads, and their security credentials are held in a token.	"Windows subjects are processes and threads."	041 - Windows Security, slide 11	041 - Windows Security::s11::1	0.50	supported (ste gate)
5	The registry is a hierarchical database holding critical system information, including security-related hives such as SAM and security logs.	"A hierarchical database containing critical system information"	041 - Windows Security, slide 4	041 - Windows Security::s04::1	0.36 LOW	partly supporte
6	The complexity of Windows security is double-edged, since misconfiguration and implementation bugs can cause severe security incidents.	"The complexity of Windows security mechanisms is also its enemy: misconfiguration as well as implementation bugs may lead to severe security incidents."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.54	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 041 - Windows Security, slide 11; 041 - Windows Security, slide 21; 041 - Windows Security, slide 4; 041 - Windows Security, slide 6

PART A - QUESTION 9

A9a - 2 marks - PLACEHOLDER

Topic: attacks/malware; command: Explain
Status: placeholder - no supported question passed verification.
Reason: A9a: sub-angle not followed; use one of ['confidentiality', 'integrity', 'availability', 'impact', 'harm', 'damage']

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the Samy worm as a case study of a self-propagating web malware attack. In your answer, explain how the worm injected and spread its payload, how victims were drawn into triggering the malicious script, and what the outcome of the outbreak was.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The worm injected JavaScript into a user profile by manipulating the page body through document.body.innerHTML.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.58	supported (ste gate)

2	The worm obtained the victim's list of friends by issuing a GET request on a user profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.22 LOW	supported
3	The worm added Samy as a friend by performing an XML-HTTP request against the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.64	supported (ste gate)
4	Any user visiting an infected profile had their own profile and friends list infected, so the worm spread from visitor to visitor.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.46 LOW	supported
5	The outbreak ultimately infected approximately one million MySpace profiles, showing the scale a web worm can reach.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15	052 - Web Security::s15::1	0.15 LOW	supported
6	Users were lured into executing the malicious script inadvertently, for example by clicking an emailed link or an infected image.	"Inadvertently click on an emailed link"	052 - Web Security, slide 13	052 - Web Security::s13::1	0.31 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two password security controls that an administrator can apply to password files and accounts in order to strengthen password-based authentication.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Access control should be applied to the password files so that they are protected from unauthorised reading.	"Access control applied to password files"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.40 LOW	partly supporte
2	Accounts should be de-activated after multiple failed login attempts to resist guessing attacks.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.55	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 12

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Based on the scenario in (a), explain how Kerberos, smartcards and single sign-on mechanisms can be used to authenticate users across a large distributed environment, giving six distinct points.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Single sign-on reduces the burden on users by	"Reduce the need to memorize passwords"	022 - Identification	022 - Identification and	0.17 LOW	supported

© Hak Cipta Universiti Teknologi MARA

	cutting down the number of passwords they must remember.		and Authentication, slide 16	Authentication::s16::1		
2	Single sign-on also saves users time because they type passwords less often.	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.18 LOW	supported
3	Kerberos is an example of a client-server single sign-on architecture.	"Client-server architectures (Kerberos, Active Directory)"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.57	supported (ste gate)
4	In Kerberos the user presents a user name and password at the client workstation to begin login.	"User enters his user name, U and password, P at a client workstation."	022 - Identification and Authentication, slide 19	022 - Identification and Authentication::s19::1	0.57	supported (ste gate)
5	Kerberos derives a secret key for the client by hashing the user's password.	"The hash value of his password KU = h(P) becomes a secret key of the client/user."	022 - Identification and Authentication, slide 19	022 - Identification and Authentication::s19::1	0.71	supported (ste gate)
6	Smartcards are listed as an alternative authentication mechanism alongside biometrics and two-factor authentication.	"Alternative user authentication mechanisms are smart cards, biometric methods and two-factor authentication."	022 - Identification and Authentication, slide 24	022 - Identification and Authentication::s24::1	0.71	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 19; 022 - Identification and Authentication, slide 24

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A junior developer at a healthcare software firm discovers that a colleague has been copying patients' records into a personal spreadsheet to speed up testing. When challenged, the colleague argues that no written rule forbids it and that the data is only used internally. The firm's management asks the security team to clarify how morals, ethics and laws apply before deciding on any action.

Question:

Explain how morals, ethics and laws differ as guides for judging the colleague's conduct, and then explain how the ACM code would direct the developer's professional behaviour in this situation.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	State that morals concern traditions of belief about right and wrong conduct, forming the basis of social behaviour.	"Morals are traditions of belief about right and wrong conduct and "doing what is morally right" is the bedrock of our social behavior"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.67	supported (ste gate)
2	Describe ethics as a set of guiding beliefs, standards or ideals held by an individual, group or community.	"Ethics is a suite of guiding beliefs, standards, or ideals that pervades an individual or a group or community of people"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.80	supported (ste gate)
3	Describe laws as formal rules of conduct imposed by a sovereign authority such as a government on its citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)
4	Note that the ACM code requires the professional to respect	"Respect privacy."	071 - Ethics and Computer Security, slide	071 - Ethics and Computer Security::s11::1	0.29 LOW	supported

© Hak Cipta Universiti Teknologi MARA

	privacy.		11			
5	Note that the professional must access computing and communication resources only when authorised or compelled by the public good.	"Access computing and communication resources only when authorized or when compelled by the public good."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.69	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 12; 071 - Ethics and Computer Security, slide 5

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

State five points about the professional code of ethics and conduct that the security team should present to management in the scenario, covering what such a code is, who defines it, an example of a professional body that issues one, and two limitations of relying on it.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A professional code of ethics is a documented set of acceptable behaviours for a professional group.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.62	supported (ste gate)
2	The code is defined by the group itself rather than imposed from outside.	"Defined by the group."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.25 LOW	supported
3	The ACM is an example of a professional body that has a code of ethics and professional conduct.	"Association of Computing Machinery ACM (founded 1947) has a code of ethics and professional conduct."	071 - Ethics and Computer Security, slide 7	071 - Ethics and Computer Security::s07::1	0.75	supported (ste gate)
4	A limitation is that the code may not reflect the ethics of every member of the group.	"May not reflect the ethical of every member of the group."	071 - Ethics and Computer Security, slide 9	071 - Ethics and Computer Security::s09::1	0.78	supported (ste gate)
5	A further limitation is that the code is often not enforceable because it is a code of conduct, not a legal document.	"Many times it isn't enforceable. It's a code of conduct, not a legal document."	071 - Ethics and Computer Security, slide 9	071 - Ethics and Computer Security::s09::1	0.60	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 6; 071 - Ethics and Computer Security, slide 7; 071 - Ethics and Computer Security, slide 9

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A hospital's file server stores patient records and administrative documents. The security team is comparing how access rights could be recorded for each file and each user, and wants a structure that is easy to verify and to manage as staff change roles.

Question:

Explain the access control structures available for implementing access policies, covering the access control matrix, access control lists and capabilities, and state the requirements such structures must satisfy.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Identify the access control matrix as one of the basic structures for implementing access policies, alongside capabilities and ACLs.	"Access control structures are mechanisms for implementing access policies:"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.50	supported (stegate)
2	State that an ACL describes access rights from the object's point of view, listing which subjects may access that object and how.	"ACL is an object-centered description of access rights:"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.50	supported (stegate)
3	Give one advantage of the access control matrix, namely that it is clearly defined and easy to verify.	"Advantages: clarity of definition easy to verify"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.38 LOW	supported
4	Name the requirements that any access control structure must meet: expressing policies, verifiability of correctness, and scalability with manageability.	"an ability to express control policies verifiability of correctness. scalability and manageability"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.46 LOW	supported
5	Note that in practice the most common instruments are ACLs, capabilities and various abstractions built on them.	"Most common practical access control instruments are ACLs, capabilities and various abstractions."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1	0.73	supported (stegate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 7; 023 - Access Control and Authorization, slide 8

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the goals that authorization aims to achieve and the role of the reference monitor in making authorization decisions, relating your discussion to the hospital file server in the scenario.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Authorization must decide, for a given subject, which objects it may access and in what manner.	"Given a subject, which objects can it access and how?"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	0.44 LOW	supported
2	Authorization must also decide, for a given object, which subjects may access it and in what manner.	"Given an object, which subjects can access it and how?"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	0.40 LOW	supported
3	The reference monitor is the component that makes the authorization decisions.	"Reference monitor makes authorization decisions."	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	1.00	supported (stegate)
4	Authorization/access control aims to achieve four goals: granting access, limiting access, preventing access, and revoking access.	"Goals of access control: Granting access Limiting access Preventing access Revoking access"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	0.70	supported (stegate)
5	In the Windows architecture, the Security Reference	"Security Reference Monitor: ACL verification"	041 - Windows Security, slide 3	041 - Windows Security::s03::1	0.40 LOW	partly supporte

© Hak Cipta Universiti Teknologi MARA

	Monitor performs ACL verification in kernel mode.					

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 4; 041 - Windows Security, slide 3

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA